
ROMHACK
In loving memory of Carola Frediani

Automated vulnerability scanning and vulnerability management

Elmar „mc.fly“ Lecher



Security advisor at the

Port of Rotterdam

Elmar „mc.fly“ Lecher





Elmar „mc.fly“ Lecher



- Hacker
- Security professional
- NPC
- Infosec / Hacker / Privacy Community, camps and conferences
- Woodworker

Elmar „mc.fly“ Lecher



- Started in the BBS age
- hacker scene since 1996
- sec conference speaker since 1999
- Computer professional since 2003
- Security professional since 2011
- Netherlands since 2016

Elmar „mc.fly“ Lecher



- Mastodon: @mcfly@milliways.social
- Matrix: @mc.fly:milliways.info

Automated vulnerability scanning and vulnerability management

Why?

- Find security vulnerabilities before someone else finds them.

Why?

- Find security vulnerabilities before someone else finds them.
  - Either a pentester
  -

Why?

- Find security vulnerabilities before someone else finds them.
  - Either a pentester
  - Or a Hacker

Why?

- Find security vulnerabilities before someone else finds them.
  - Either a pentester
  - Or a threat actor

Why?

- Better Code

Why?

- Better Code
- Others might use this

Why?

- …. because we’re the security people and that’s what we do?

Categorisation

What kind of tools exist?

What can I scan?

- Network
- Hosts
- Application
- Cloud
- Database
- Container
- Source code

What can I scan?

- Network
- Hosts
- Application

- Cloud
- Database
- Container
- Source code

… and a lot of small specialists

How can I scan?

- External
- Internal

- Authenticated
- Unauthenticated

How can I scan?

- Sevice
- Self hosted scan

Licence of scanner?

- Open Source
- Enterprise service

Network scanners

- Tools scanning the network:
- Tools scanning Network devices

Network scanners

- Tools scanning the network:
  - Nmap
  - Zmap
  - Shodan

Network scanners

- Tools scanning Network devices
  - Ios-iosxe-security-scanner
  - qualys

Host scanners

Scans a host which can be a physical server or a VM

rather straightforward.

Host scanners

- OpenVAS
- Nessus
- MS Defender for Endpoint

Cloud scanners

Now that mostly depends on your definiton for cloud.

Mass scaler cloud infra vs. „the cloud stack“

Cloud scanners

- Kubeaudit
- Terrascan
- MS Defender for cloud

Cloud scanners

- ~~Kubeaudit~~ Deprecated since October 2024
- Terrascan
- MS Defender for cloud

Cloud scanners

- Kube-bench
- Trivy
- Terrascan
- MS Defender for cloud

Database scanners

- Scans your database for excessive user rights, config mistakes etc.

Database scanners

- MS SQL Server Vulnerability Assessment
- Oracle Database Security Assessment Tool
- MySQL Vulnerability scanner

Container scanners

Scans your (docker) containers for common security issues and more

- 100 most common mistakes in Docker
- Packages and libaries in the container with CVEs

Application scanners

Scans an application

I refer here to scanners that scan the installed application.

General / specific

Application scanners

- Zap
- WPAudit / WPScan
- Nikto
- OpenVAS
- Prowler (for aws / Azure / GC / Kubernetes)

Source code scanners

Scans your code, usually directly in the repo

We used to know them as linters but today we'd likely call them Static code analysis tools.

Here we find a lot of specialists

Source code scanners

This contains scanning for dependencies as much as for things like credentials and tokens – but also Infrastructure as code.

Source code scanners

- Sonarcube
- Snyk
- Veracode
- Github Vulnerability

Source code scanners

- Bandit, pip-audit (for python)
- Brakeman, Dawnscanner (for Ruby)
- GolangCI-Lint, nancy (for Golang
- Nodejsscan (for nodeJS)
- PHPSecurityAudit, PHPStan (for PHP)

Source code scanners

- Trufflehog – for finding credentials
- gitleaks
- Etc etc...

The small specialists

- Ssltest.sh tests your TLS
- Hydra tests your passwords

AI

AI

Source code analysis works great in AI

AI

Source code analysis works great in AI

Finding certain security bugs the LLMs are really good at.

AI

Source code analysis works great in AI

Most other stuff is more meh

AI

A lot of security tools added AI to it lately.

AI

A lot of security tools added AI to it lately.

be sceptical of that.

AI

A lot of security tools added AI to it lately.

My impression is that a lot of that AI was added to get funds.

Automatisation

- Automate your scans

Automatisation

- Automate your scans
- Scan frequently for code and binary repositories
- Scan frequently on hosts and infrastructure
- Scan on commit / merge / build

Vulnerability Management

So you find vulnerabilities.

Vulnerability Management

So you find vulnerabilities.

So you fix them.

Vulnerability Management

So you find vulnerabilities.

So you fix them.

Right?

What is actually the problem?

Why?

- Security tests identified vulnerabilities but they were not treated
- Fixing of software took long – but we did not know how long
- The teams and especially the PO had no idea what the vulnerability situation is

Why?

- Numbers being reportet to management felt made up
- Risk Register was swamped with (threats and) Vulnerabilities.
- Information was at too many and too few points at the same time

Why?

Most importantly

- Enable to have more security test

  Usually there’s too many and too few tests at the same time.

What is Vulnerability Management?

What is Vulnerability Management?

Wikipedia says its a „cyclical practice of

- identifying,
- classifying,
- prioritizing,
- remediating, and
- mitigating

software vulnerabilities“

Identifying vulns

- Pentests
- Vulnerability scanners
- Static code analysis
- Infrastructure scanner
- …
- All of your security scanners.

Identifying vulns

the hard part: Is this a false positive?

False positives are the bane of security testing.

Foreshadowing on later: a tool should help you there

classifying vulns

- Is this critical?
- Is this exploitable?

And sometimes:

- Which teams have to fix it?

prioritizing of vulns

I am sure you know this and i don’t have to explain it….

prioritizing of vulns

I am sure you know this and i don’t have to explain it….

Basically: what do you fix first

Remediation of vulns

Solve the root cause of the vulnerability

This is the proper path that should always be prefered.

I need to repeat that to the PO’s.

Remediation of vulns

- Update
- Fix in code
- Update the libaries

Remediation of vulns

- Update
- Fix in code
- Update the libaries
- Install updates

Mitigation of vulns

Make it impossible to exploit the vulnerability

can we firewall that off?

Mitigation of vulns

Make it impossible to exploit the vulnerability

can we firewall that off?

can we filter that out?

Vuln Mngt Software

Helps you to streamline the whole vulnerability management process.

Vuln Mngt Software

Helps you to streamline the whole vulnerability management process.

If you don’t have a dedicated vulerability management software….

Vuln Mngt Software

Helps you to streamline the whole vulnerability management process.

If you don’t have a dedicated vulerability management software its likely this:


Excel

Excel is not a solution.

- Most common vulnerability management solution
- It sucks
- Lots of ctrl-c ctrl-v in the process
- Mostly manual work
- Did i say it sucks for this task?

Better tools

Friends don’t let friends use excel

There are better tools. But not all of them are good.

Better tools

There are a lot of Vulnerability Scanners who now have a Vulnerability Management tooling attached.

Better tools

There are a lot of Vulnerability Scanners who now have a Vulnerability Management tooling attached.

In general: if this is not the only tool you (want to) use its a shit solution.

Better tools



Microsoft Defender Vulnerability Management

If the **only** security tools you use are the Microsoft defenders then this might be for you.

For the others: likely not

Better tools



Microsoft Defender Vulnerability Management

But if its for you you’re likely not watching this talk anyway.

Better tools

DefectDojo

What is DefectDojo?

DefectDojo is an open-source application vulnerability management correlation and security orchestration tool.

DefectDojo

Open source & an OWASP project

DefectDojo

vulnerability management

DefectDojo

vulnerability management tool

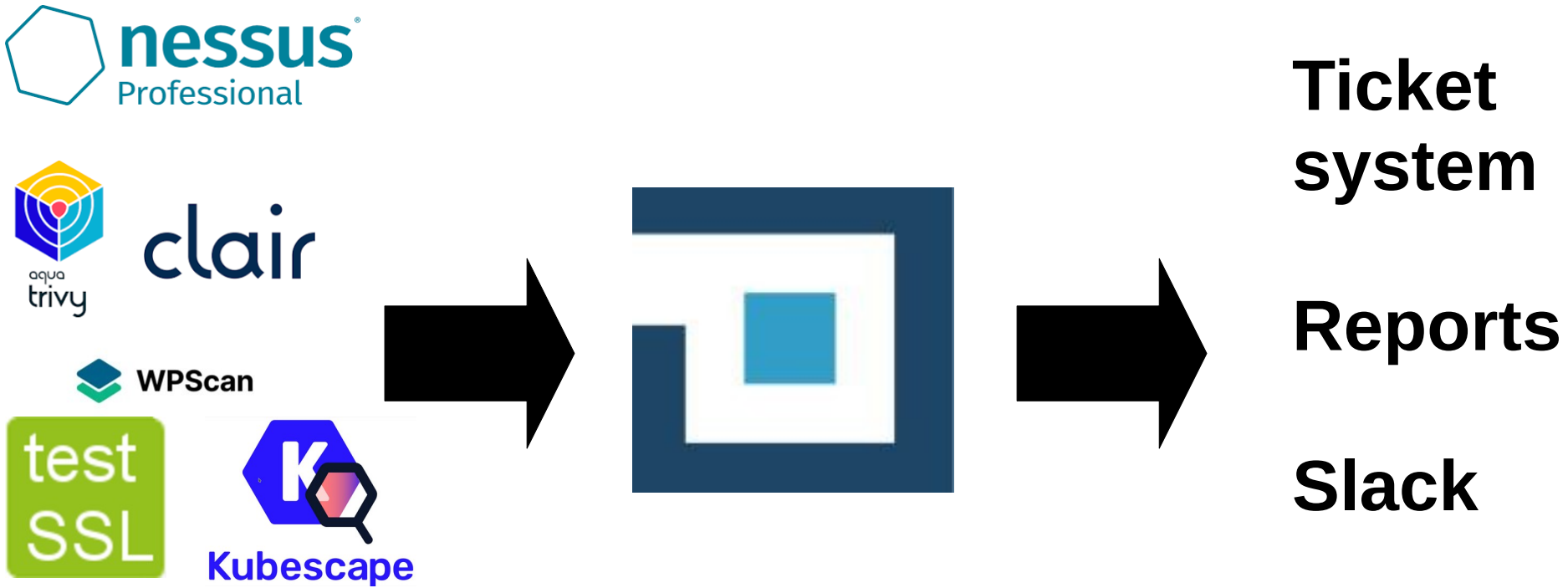
(the thing we talked about earlier)

What does DefectDojo do?

DefectDojo is an open source vulnerability management tool that

- streamlines the process of dealing with results from the testing process by
- integration of templating,
- report generation,
- metrics, and
- baseline self-service tools.

DefectDojo simple overview



And scanners that make reports in JSON and XML

DefectDojo simple overview

Products have

Engagements that find

vulnerabilities

Identifying vulns

the hard part: Is this a false positive?

False positives are the bane of security testing.

Some vulns are found by multiple tools

Vulnerability Management

Imports work via JSON, CSV, XML or via API

Has a massive API

exports into comunication tools, ticket systems

Thank you for coming and listening

make your work open source.

Questions?

The end (for now)